

Teoria 3 Parte 0 - Proceso Forense

Supply Chain Attack

- **Concepto:**

IFX es un proveedor. Cuando cae algún eslabón de la cadena de proveedores, todo el resto de los componentes se ven afectados.

- **Impacto regional:**

- Empresas y organismos gubernamentales de **Argentina, Colombia, Chile y Panamá** afectados.
- Información no oficial: de los **19.301 sitios web alojados**, se estima que **14.902 quedaron sin servicio** casi ocho días después del ataque de ransomware.
- **762 empresas** afectadas.

```

Welcome to the RansomHouse
You are locked by
M A R I O

Dear IFX management,
If you are reading this message, it means that:
- your network infrastructure has been compromised,
- clients' critical data was leaked,
- backups destroyed,
- files are encrypted.
The best and only thing you can do is to contact us
to settle the matter before any losses occurs.
Check out our website: http://zohlm7a\[REDACTED\].onion/
Telegram Channel: https://t.me/RHous\[REDACTED\]

-----
1. THE FOLLOWING IS STRICTLY FORBIDDEN
1.1 EDITING FILES ON HDD.
    Renaming, copying or moving any files
    could DAMAGE the cipher and
    decryption will be impossible.
1.2 USING THIRD-PARTY SOFTWARE.
    Trying to recover with any software
    can also break the cipher and
    file recovery will become a problem.
1.3 SHUTDOWN OR RESTART THE PC.
    Boot and recovery errors can also damage the cipher.
    Sorry about that, but doing so is entirely at your own risk.
```

El Proceso Forense

La evidencia digital presenta desafíos para su **admisibilidad legal**, por lo que es necesario aplicar procesos forenses adecuados, estructurados en **cuatro fases**:

1. Recolección
2. Examinación / Extracción
3. Análisis
4. Reporte

1. Recolección

La fase de recolección implica la **búsqueda, reconocimiento, documentación y preservación de la evidencia digital**.

Puede involucrar información en tiempo real o almacenada, susceptible de ser alterada si no se toman precauciones.

El proceso de recolección constituye una serie de pasos

- Relevamiento inicial del caso
- Admisión del caso
- Valoración de la evidencia
- Adquisición y verificación de la evidencia
- Uso de herramientas
- Análisis preliminar

a. Relevamiento inicial del caso

Datos mínimos a registrar:

- Responsable del equipo
- Usuarios del sistema
- Modelo, descripción y número de serie
- Sistema operativo en uso
- Costos económicos aproximados del incidente
- Otros detalles según el objetivo del análisis

b. Admisión del caso

- Confirmar autorización legal (pedido judicial o privado).
- Contar con formulario de asistencia completo.
- Documentación sobre cadena de custodia (en caso de allanamiento).
- Explicar alcances y limitaciones de la forensia.
- Solicitar información complementaria (ej. orden de preservación a ISP).
- Considerar componentes anexos (tarjetas de crédito, impresoras, etc.).
- Definir evidencia esencial (fotos, bases de datos, planillas, etc.) y datos adicionales (alias, correos, cuentas, ISP usados).
- Evaluar el **skill** de los usuarios involucrados (ocultamiento, cifrado, esteganografía).

- Priorizar orden de análisis.
- Determinar necesidad de personal o equipamiento adicional.
- Evaluar si el caso corresponde a la propia expertise y, de no ser así, excusarse.

c. Valoración de la evidencia

Dependerá del **foco de la investigación**:

- No es igual un caso de malware que uno de fraude o recuperación de fotos.
- Se deben considerar:
 - Autorizaciones legales
 - Detalles del caso
 - Naturaleza de hardware/software
 - Valor de la evidencia
 - Dificultades de adquisición

d. Escena del crimen

La evidencia digital puede hallarse en diversos dispositivos, sensibles a golpes o pérdida de energía.

Procedimientos iniciales

- Asegurar toda la evidencia electrónica.
- Restringir acceso a personal autorizado.
- Mantener condición de los dispositivos sin alteración.
- No encender dispositivos apagados.

Si el equipo está encendido o su estado es incierto

- Observar señales (coolers, LEDs, pantalla).
- Detectar posible destrucción de datos.
- Verificar conexiones remotas activas.
- Revisar cámaras/webcams encendidas.

Cuándo desconectar el equipo

- Cuando la información que se observa en la pantalla indica que la información se está borrando o sobrescribiendo.
- Hay alguna indicación que un proceso destructivo se está ejecutando en los dispositivos de almacenamiento del equipo
- Si corre Windows: desconectar preserva datos como últimos accesos y comandos usados.

Cuándo NO desconectar el equipo

- Si hay datos que aparentan ser evidentemente importantes están en la pantalla.
 - Si hay actividad en: redes sociales, chats, documentos abiertos, repositorios remotos, pornografía infantil, contrabando, finanzas, cifrado, u otras actividades ilegales.
-

2. Examinación / Extracción

Objetivo: **hacer visible la evidencia y explicar su origen y significado.**

Requisitos:

- Documentar contenido y estado completo.
 - Facilitar comprensión a otras partes.
 - Buscar información oculta.
 - Reducir datos conservando solo lo valioso.
-

4. Análisis

- Se investiga la evidencia encontrada en la examinación.
 - Diferencia clave:
 - **Examinación** → técnica, identifica información.
 - **Análisis** → interpretativa, da valor probatorio al caso.
 - Generalmente realizado por un grupo de investigación.
-

5. Reporte

El informe debe describir **procesos y hallazgos**.

Suelen presentarse dos tipos:

- **Ejecutivo / Gerencial** → visión abstracta y resumida.
 - **Técnico** → detalle exhaustivo a bajo nivel.
-

6. Fuentes de información

Computadora

- Hardware, software y periféricos.
- Evidencia potencial: archivos en discos duros/dispositivos.

Componentes (IoT y anexos)

- Dispositivos IoT, TVs, electrodomésticos inteligentes.
- Evidencia: registros de actividad, datos almacenados.

Memorias

- RAM: procesos en ejecución, conexiones, comandos recientes.
- Memorias congeladas: técnicas para preservar contenido temporal.

Dispositivos de control de acceso

- Smartcards, biometría, llaves de cifrado.
- Evidencia: autenticación, configuraciones, permisos.

Cámaras digitales

- Evidencia: imágenes, audios, videos, metadatos de fecha/hora.

Discos duros / externos

- Evidencia: todo el file system.

Tarjetas de memoria

- Usadas en cámaras, teléfonos, computadoras.
- Evidencia: igual al file system.

Impresoras y scanners

- Evidencia: documentos impresos, logs, configuraciones.
- Imperfecciones del scanner permiten rastrear origen.

Medios extraíbles y unidades flash

- Almacenamiento portátil (USB, cartuchos, etc.).
- Evidencia: idéntica a la de discos duros.

Dispositivos de mano / portátiles

- Smartphones, tablets, GPS, etc.
- Evidencia: software, datos personales, correos, chats, fotos, bases de datos, finanzas.
- Riesgo: borrado remoto, sobreescritura de datos.
- Precaución: aislar con jaula de Faraday.

Periféricos

- Teclados, mouse, faxes, etc.
- Evidencia: huellas, ADN, registros de uso.

Redes de computadoras

- PCs, routers, switches, hubs, impresoras conectadas.
 - Evidencia: direcciones IP, MAC, configuraciones, registros de conexión.
-

7. Equipo y herramientas de investigación

Para preservar evidencia sin alterarla, deben evitarse materiales con electricidad estática o campos magnéticos.

Materiales recomendados:

- Cámaras de fotos y video
- Guantes
- Inventario de evidencias
- Cinta y etiquetas de evidencia

- Bolsas de papel y bolsas antiestáticas
- Cinta de escena del crimen
- Marcadores permanentes
- Herramientas no magnéticas
- Bolsas de Faraday o aluminio para móviles

Normas Internacionales

2.1 ISO/IEC 27037:2012

Guía para la **identificación, recolección, adquisición y preservación de evidencia digital**.

- **Objetivo:**
 - Establecer pautas sobre el manejo de evidencia digital.
 - Facilitar procedimientos disciplinarios e intercambio de evidencia entre jurisdicciones.
- **Dispositivos contemplados:**
 - Medios de almacenamiento (discos, disquetes, ópticos, magneto-ópticos).
 - Teléfonos celulares, PDA, tarjetas de memoria.

- Sistemas de navegación móviles.
 - Cámaras digitales y CCTV.
 - Computadoras con conexión a red.
 - Redes TCP/IP y otros protocolos digitales.
 - **Principios fundamentales:**
 - **Metodología:** métodos no intrusivos o mínimamente intrusivos.
 - **Auditoría:** trazabilidad y revisión por terceros.
 - **Reproducción:** resultados replicables con las mismas condiciones.
 - **Defensa:** justificar herramientas y procedimientos utilizados.
 - **Fases del tratamiento de la evidencia:**
 - **Identificación:** localizar evidencia (física o lógica).
 - **Adquisición:** copia forense + documentación asociada.
 - **Preservación:** conservar la evidencia inalterada manteniendo la cadena de custodia.
 - **Criterios de validez de la evidencia digital:**
 1. **Relevancia** → relación directa con hipótesis del caso.
 - Preguntas clave: ¿vincula al sujeto con el hecho? ¿prueba una hipótesis concreta?
 2. **Confiabilidad** → repetibilidad y auditabilidad del proceso.
 - Preguntas clave: ¿las herramientas fueron probadas y auditadas? ¿tienen tasa de error conocida?
 3. **Suficiencia** → completitud de la evidencia.
 - Preguntas clave: ¿la evidencia recolectada es suficiente para sostener conclusiones?
-

2.2 RFC 3227 – Guidelines for Evidence Collection and Archiving

- **Propósito:** Directrices para la **recolección y almacenamiento de evidencias digitales**.
- Funciona como un estándar de facto en incidentes de seguridad.

Orden de volatilidad (de mayor a menor):

1. Registros y cachés.
2. Tablas de enrutamiento, ARP, procesos, estadísticas del kernel, memoria.
3. Información temporal del sistema.
4. Disco.
5. Logs del sistema.
6. Configuración física y topología de la red.
7. Documentos.

Acciones que deben evitarse

- No apagar el equipo antes de recopilar información.
- No confiar en información del sistema comprometido.
- No ejecutar programas que alteren fechas y accesos.

Consideraciones de privacidad

- Siempre requerir **autorización por escrito**.
- Evitar recopilar datos personales irrelevantes.
- Proteger la confidencialidad y disponibilidad de servicios.

Herramientas recomendadas

- Examen de procesos → `ps`.
 - Estado del sistema → `showrev`, `ifconfig`, `netstat`, `arp`.
 - Copias bit a bit → `dd`, `SafeBack`.
 - Hashes → `sha1sum`, `pgp`.
 - Imágenes de memoria → `gcore`, `gdb`.
-

3. Protocolos Nacionales (Argentina)

3.1 Protocolo unificado de los Ministerios Públicos (2017)

- Guía para **levantamiento y conservación de evidencia**.

- Define principios y condiciones generales de aceptación en laboratorios forenses.
- Requiere documentar **cadena de custodia** desde el levantamiento hasta el análisis.

Principios generales

- **Representatividad:** evidencias vinculadas correctamente al lugar, tiempo y hechos.
- **Identidad:** identificación clara e indeleble (materiales resistentes, etiquetas a prueba de agua).
- **Integridad:** envases resistentes, herméticos, sin pérdidas.
- **Peligrosidad:** declaración escrita en caso de sustancias peligrosas.

Elementos para la identificación

- Lugar, hora, fecha, tipo de muestra.
- Número de causa, juez/fiscal interviniente.
- Firmas de responsables.
- Precinto.
- Planilla de cadena de custodia firmada por cada interviniente.

3.2 Evidencias digitales – Principios generales

- **Qué son:** PC, notebooks, tablets, celulares, pendrives, CD/DVD, discos duros, servidores.
- **Operativa:**
 - Secuestro selectivo, no masivo.
 - Evitar manipulación de equipos (no encender, no presionar teclas).
 - Documentar y fotografiar todo.
 - Respetar **orden de volatilidad** (primero registros en memoria, luego disco).
 - Usar guantes y bolsas antiestáticas/Faraday.

TIPO DE MUESTRA	RECOLECCIÓN	PREPARACIÓN	EMBALAJE
Estado de la memoria RAM	Capacidad de los programas cargados. Bloqueos. Porcentaje de uso		
Procesos activos	Uso de CPU. Dependencias de procesos y componentes		
Conexiones de red	Conexiones actuales con otras PC y servidores	Identificación de elementos con respaldo de impresiones, fotografías y actas	No instalar programas en las PC. Realizar las operaciones con los equipos encendidos y cables conectados
Impresiones activas	Cola de impresión local. Documentos sin imprimir. Estado y descripción de los documentos que se están imprimiendo		
Fecha y hora del sistema operativo	Fecha y hora del sistema operativo. Zona horaria. Sincronizaciones con servidores de hora en Internet		
Red de la empresa u organización	Características. Tráfico. Congestión. Bloqueos. Snifers activos. Virus de red		
TIPO DE MUESTRA	RECOLECCIÓN	PREPARACIÓN	EMBALAJE
Papeles impresos	Recolección de papeles impresos en el lugar	Identificación de elementos con respaldo de fotografías y actas	
Conexiones físicas de red	Cableados existentes. Hubs. Switchs	Identificación de elementos con respaldo de fotografías y actas	No desconectar hasta tanto se recolecte y documente la evidencia

3.3 Pasos en la escena del crimen / allanamiento

- Separar usuarios de los dispositivos.
- Identificar personal informático interno (admins, programadores).
- Obtener contraseñas y patrones de bloqueo.
- Fotografiar equipos antes de moverlos.
- Equipos apagados → mantener apagados.
- Equipos encendidos → consultar especialista, de no haberlo, desconectar cable de corriente del gabinete.

- Celulares → apagar, extraer batería si es posible, activar modo avión, proteger botón de encendido.
 - Dispositivos en uso → si es necesario mantenerlos encendidos, aislar en bolsa de Faraday.
 - Registrar todo cambio realizado.
-

3.4 Protocolo de Actuación para la Investigación Científica en el Lugar del Hecho (2021)

- Introduce la figura del **Especialista en informática forense**.
- Define sus **responsabilidades, atribuciones y funciones**.
- Enumera los **PEPS (Potenciales Elementos de Prueba)** a identificar.
- Establece pautas para:
 - Actuación en distintas situaciones.
 - Solicitud de autorizaciones.
 - Forma de informar hallazgos.
- Reafirma la importancia de la **cadena de custodia**.